1
Understanding Security Fundamentals

In this chapter, we are going to look at some security fundamentals that will help you identify security threats in the system and mitigate them. With cybercrime increasing day by day, as an **Information Technology** (**IT**) professional, it is essential to first understand these fundamental concepts.

In this chapter, we will be covering the following topics:

- Security Fundamentals
- Comparing Control Types
- Physical Security Controls
- Understanding Digital Forensics

Let's start by looking at security fundamentals.

Security Fundamentals

The fundamentals of security are the foundation of protecting our assets, and there must be a strategy or methodology that we adapt for security. This is the CIA triad; let's look at its breakdown.

CIA Triad Concept

Most security books start with the basics of security by featuring the CIA triad—this is a conceptual model designed to help those writing information security policies within an organization. It is a widely used security model and it stands for confidentiality, integrity, and availability, the three key principles that should be used to guarantee you have a secure system:

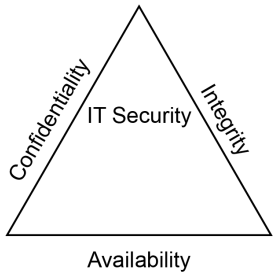


Figure 1.1 – CIA triad

We'll discuss these principles in more depth here:

- **Confidentiality**: Prevents the disclosure of data to unauthorized people so that only authorized people have access to data. This is known as the need-to-know basis. Only those who should know the contents should be given access. An example would be that your medical history is only available to your doctor and nobody else.

  We also tend to encrypt data to keep it confidential. There are two types of encryption, known as symmetric and asymmetric. Symmetric encryption uses one key, known as the secret key. Asymmetric encryption uses two keys, known as the private key and the public key.

- **Integrity**: This means that you know that data has not been altered or tampered with. We use a technique called hashing that takes the data and converts it into a numerical value called a hash or message digest. When you suspect changes have taken place, you would check the hash value against the original. If the hash value has changed, then the data has been tampered with. Common hashing algorithms covered in the exam are **Secure Hash Algorithm Version 1** (**SHA1**) 160-bit and **Message Digest Version 5** (**MD5**) 128-bit. SHA1 is more secure than MD5; however, MD5 is faster. The higher the number of bits, the more secure, and the lower the number, the faster it is.
- **Availability**: Availability ensures that data is always available; an example would be if you wanted to purchase an airplane ticket and the system came back with an error saying that you could not purchase it. This could be frustrating, and therefore, availability is important. Examples of availability include **Redundant Array of Independent Disks** (**RAID**), which allows one or two disks to fail while still keeping the data available. Another example may be a fail-over cluster. In this, two servers can access the same data, and if one fails, the other can still provide the data, a data backup, or **Heating Ventilation Air Conditioning** (**HVAC**) that regulates the temperature for critical servers. In a datacentre, if the temperature is too hot then the servers will shut down.

Least Privilege

Least Privilege is where you give someone only the most limited access required so that they can perform their job role; this is known as a *need-to-know* basis. The company will write a least privilege policy so that the administrators know how to manage it.

Defense in Depth Model

Defense in Depth is the concept of protecting a company's data with a series of protective layers so that if one layer fails, another layer will already be in place to thwart an attack. We start with our data, then we encrypt it to protect it:

- The data is stored on a server.
- The data has file permissions.
- The data is encrypted.

- The data is in a secure area of the building.
- There is a security guard at the building entrance checking identification.
- There is CCTV around the perimeter.
- There is a high fence around the perimeter.

Let's look at this from the intruder's perspective, trying to jump the fence, and see how many layers they have to circumvent:

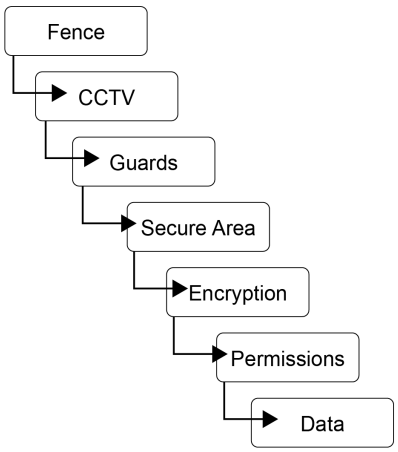


Figure 1.2 – Defense in Depth model

Let's now compare the different control types.

Comparing Control Types

There is a wide variety of different security controls that are used to mitigate the risk of being attacked; the three main categories are managerial, operational, and technical. We are going to look at these in more detail; you need to be familiar with each of these controls and when each of them should be applied. Let's start by looking at the three main controls.

Managerial Controls

Managerial Controls are written by managers to create organizational policies and procedures to reduce risk within companies. They incorporate regulatory frameworks so that the companies are legally compliant. The following are examples of management controls:

- **Annual Risk Assessment**: A company will have a risk register where the financial director will look at all of the risks associated with money and the IT manager will look at all of the risks posed by the IT infrastructure. As technology changes and hackers get more sophisticated, the risks can become greater. Each department will identify their risks and the risk treatments, and place them in the risk register. These should be reviewed annually.
- **Penetration Testing/Vulnerability Scanning**: A vulnerability scan is not intrusive as it merely checks for vulnerabilities, whereas a penetration test is more intrusive, as it goes deeper into a computer and can exploit vulnerabilities. It could cause the system to crash unexpectantly. These will be explained further later in this book.

Operational Controls

Operational controls are executed by company personnel during their day-to-day operations. Examples of these are the following:

- **Annual Security Awareness Training**: This is an annual event in which you are reminded about what you should be doing each day to keep the company safe:

  Example 1 – When you are finished for the day, you should clear your desk and lock all documents away.

  Example 2 – Employees and visitors should wear an identity badge at all times. If they do not, they should be challenged.

  Example 3 – Companies need their employees to complete annual cybersecurity training as the risk is getting greater each day.
- **Change Management**: This is a process that a company adopts so that changes made don't cause any security risks to the company. A change to one department could impact another department. The **Change Advisory Board** (**CAB**) assists with the prioritization of changes; they also look at the financial benefits of the change and they may accept or reject the changes proposed for the benefit of the company. IT evolves rapidly and our processes will need to change to cope with the potential security risks associated with newer technology.

- **Business Continuity Plan**: This is contingency planning to keep the business up and running when a disaster occurs by identifying any single point of failure that would prevent the company from remaining operational.

Technical Controls

Technical Controls are those implemented by the IT team to reduce the risk to the business.

These could include the following:

- **Firewall Rules**: Firewalls prevent unauthorized access to the network by IP address, application, or protocol. These are covered in depth later in this book.
- **Antivirus/Antimalware**: This is the most common threat to a business, and we must ensure that all servers and desktops are protected and up to date.
- **Screen Savers**: These log computers off when they are idle, preventing access.
- **Screen Filters**: These prevent people that are walking past from reading the data on your screen.
- **Intrusion Prevention System (IPS)/Intrusion Detection System (IDS)**: An IDS monitors the network for any changes and an IPS stops the attacks. If you do not have an IDS, the IPS can also fulfill the role of the IDS. These are covered more in-depth in *Chapter 7*.

Let's now look at other control types, from deterrents to physical controls, when we try and stop attacks at the source.

Deterrent Controls

Deterrent Controls could be CCTV and motion sensors. When someone is walking past a building and the motion sensors detect them, it turns the lights on to deter them. A building with a CCTV camera in a prominent position and a sign warning people that they are being recorded may act as a deterrent.

Detective Controls

Detective Controls are used to investigate an incident that has happened and needs to be investigated; these could include the following:

- **CCTV** records events as they happen and from that, you can see who has entered a particular room or has climbed through a window at the rear of a building. CCTV can capture motion and provide non-repudiation.
- **Log Files** are text files that record events and the times that they occurred; they can log trends and patterns over a period of time. For example, servers, desktops, and firewalls all have event logs that detail actions that happen. Once you know the time and date of an event, you can gather information from various log files. These can be stored in **Write-Once Read-Many** (**WORM**) drives so that they can be read but not tampered with.

Corrective Controls

Corrective Controls are the actions you take to recover from an incident. You may lose a hard drive that contained data; in that case, you would replace the data from a backup you had previously taken.

Fire Suppression Systems are another form of corrective control. There may have been a fire in your data center that destroyed many servers, therefore, when you purchase replacement servers, you may install an oxygen suppressant system that will starve a fire of the oxygen needed. This method uses argon/nitrogen and carbon dioxide to displace the oxygen in the server room.

Compensating Controls

Compensating Controls can also be called **Alternative** or **Secondary Controls** and can be used instead of a primary control that has failed or is not available. Once a primary control has failed, we need a secondary control. This is similar to when you go shopping and you have $100 in cash—once you have spent your cash, you will have to use a credit card as a compensating control.

Example: When a new employee arrives, they should log in using a smart card and PIN. It may take 3–5 days to get a new smart card, so during the waiting period, they may log in using a username and password.

Preventative Controls

Preventative Controls are in place to deter any attack; this could be having a security guard with a large dog walking around the perimeter of your building. This would make someone trying to break in think twice about doing so. Some of the preventive measures that can be taken are as follows:

- **Disable User Accounts**: When someone leaves a company, the first thing that happens is that their account is disabled, as we don't want to lose information that they have access to, and then we change the password so that they cannot access it. We may also disable an account while people are on secondment, maternity leave or if we find that account has been used in an attack on our network.
- **Operating System Hardening**: This makes a computer more secure, where we ensure that the operating system is fully patched and turn off unused features and services. This will ensure that there will be no vulnerabilities. The US Department of Defence (DOD) has a guide called the Security Technical Implementation Guide (STIG), this contains guidance on how to 'lock down' the computer systems and software to prevent them from being vulnerable to attack.

Access Controls

The three main parts of access controls are identifying an individual, authenticating them when they insert a password or PIN, and then authorization, where an individual is granted permission to the different forms of data. For example, someone working in finance will need a higher level of security clearance and have to access different data than a person who dispatches an order in finished goods:

- **Identification**: This is similar to everyone having their own bank account; the account is identified by the account details on the bank card. Identification in a secure environment may involve having a user account, a smart card, or maybe some sort of biometrics such as fingerprint or face as these are unique to each individual. Each person has their own **Security Identifier** (**SID**) for their account, which is like an account serial number.
- **Authentication**: Once the individual inserts their method of identification, they next have to be authenticated, for example, by inserting a password or a PIN.
- **Authorization**: This is the level of access or permissions that you have to apply to selected data. You are normally a member of certain groups, for example, a sales manager could access data from the sales group and then access data from the managers' group. You will only be given the minimum amount of access required to perform your job; this is known as least privilege.

Discretionary Access Control

Discretionary Access Control is similar to the **New Technology File System** (**NTFS**) file permissions, which are used in Microsoft operating systems. The user is only given the access that they need to perform their job. They are sometimes referred to as user-based or user-centric. The permissions are as follows:

- **Full Control**: Full access.
- **Modify**: Change data, read, and read and execute.
- **Read and Execute**: Read the file and run a program if one is inside it.
- **List Folder Contents**: Expand a folder to see the subfolders inside it.
- **Read**: Read the contents.
- **Write**: This allows you to write to the file.
- **Special Permissions**: Allows granular access; for example, it breaks each of the previous permissions down to a more granular level.
- **Data Creator/Owner**: The person that creates the unclassified data is called the owner and they are responsible for checking who has access to that data.

The following diagram shows a user called *Ian* who has **Read** and **Read & Execute** permissions:

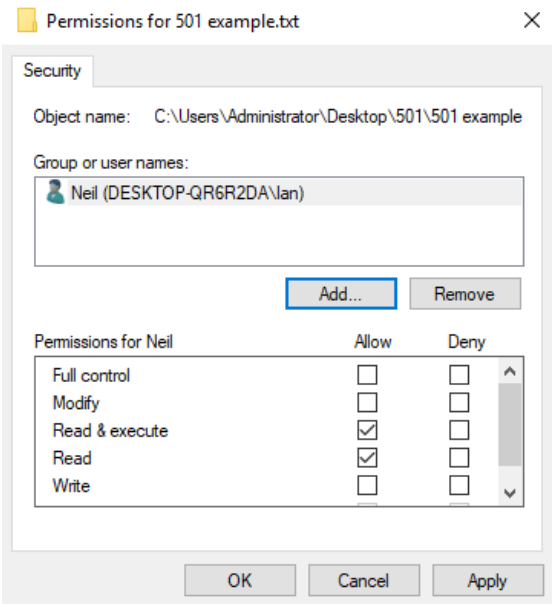


Figure 1.3 – DAC file permissions

Mandatory Access Control

Mandatory Access Control (**MAC**) is based on the classification level of the data. MAC looks at how much damage could be inflicted to the interests of the nation. These are as follows:

- **Top secret**: Highest level, exceptionally grave damage
- **Secret**: Causes serious damage
- **Confidential**: Causes damage
- **Restricted**: Undesirable effects

Examples of MAC based on the classification level of data are as follows:

- **Top secret**: Nuclear energy project
- **Secret**: Research and development
- **Confidential**: Ongoing legal issues

MAC Roles

Once classified data has been written, it is owned by the company. For example, if a Colonel writes a classified document, it belongs to the Army. Let's look at three roles:

- **Owner**: This is the person who writes data, and they are the only person that can determine the classification. For example, if they are writing a secret document, they will pitch it at that level, no higher.
- **Steward**: This is the person responsible for the quality and labeling of the data.
- **Custodian**: The custodian is the person who stores and manages classified data. The custodian ensures the data is encrypted and backed up.
- **Security Administrator**: The security administrator is the person who gives access to classified data once clearance has been approved.

Role-Based Access Control

Role-based access control is a subset of the department carrying out a subset of duties within a department. An example would be two people within the finance department who only handle petty cash. In IT terms, it could be that only two people on the IT team administer the email server.

Rule-Based Access Control

In **Rule-Based Access Control** (**RBAC**), a rule is applied to all of the people within a department, for example, contractors will only have access between 8 a.m. and 5 p.m., and the help desk people will only be able to access building 1, where their place of work is. It can be time-based or have some sort of restriction, but it applies to the whole department.

Attribute-Based Access Control

In **Attribute-Based Access Control** (**ABAC**), access is restricted based on an attribute in the account. John could be an executive and some data could be restricted to only those with the executive attribute. This is a user attribute from the directory services, such as a department or a location. You may wish to give different levels of control to different departments.

Group-Based Access Control

To control access to data, people may be put into groups to simplify access. An example would be if two people worked in IT who needed access to IT data. For example, let's call them *Bill* and *Ben*. We first place them into the IT group, and then that group is given access to the data:

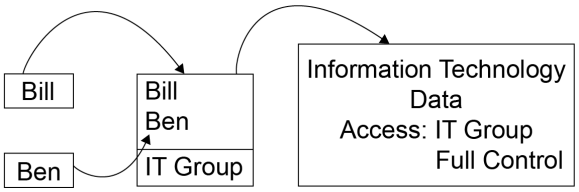


Figure 1.4 – Group-based access

Another example is where members of a sales team may have full control of the sales data by using group-based access, but you may need two new starters to have only read access. In this case, you would create a group called new starters and give those people inside that group only read permission to the data.

Linux-Based Access Control

In this section, we are going to look at Linux file permissions. These appear frequently in the Security+ exam even though they are not covered in the exam objectives.

Linux File Permissions (not SELinux)

Linux file permissions come in a numerical format; the **first number** represents the **owner**, the **second number** represents the **group**, and the **third number** represents **all other** users:

a. Permissions:

- **Owner**: First number
- **Group**: Second number
- **All other users**: Third number

b. Numerical values:

- **4**: Read
- **2**: Write
- **1**: Execute

Unlike a Windows permission that will execute an application, the execute function in Linux allows you to view or search. A permission of 6 would be read and write. A value of 2 would be write, and a value of 7 would be read, write, and execute. Some examples are as follows:

- *Example 1*: If I have *764* access to *File A*, this could be broken down as follows:

  a. **Owner**: Read, write, and execute

  b. **Group**: Read and write

  c. **All other users**: Read

  Another way the permissions can be set is by alphabetical values, as shown:

  a. **R:** Read

  b. **W**: Write

  c. **X**: Execute

  When using alphabetical values, each set of permission is shown as three dashes. Full control for the three entities are as follows:

  a. **Owner Full Control**: `rwx --- ---`

  b. **Group Full Control**: `--- rwx ---`

  c. **All Other Users Full Control**: `--- --- rwx`

- *Example 2*: If a file has an access level of `rwx rwx rw-`, what does this mean?

  a. Owner has read, write, and execute (full control).

  b. Group has read, write, and execute (full control).

  c. All other users have only read and write permissions.

Physical Security Controls

Physical security controls are put in place to stop unauthorized access to the company or accessing the data. Physical security controls are easily identifiable as you can touch them. Let's look at each of them in turn.

Perimeter Security

In this section, we will look at different types of perimeter security systems:

- **Signage**: Before anyone reaches your main entrance, there should be highly visible signs warning them that they are entering a secure area with armed guards and dogs. This is used as a deterrent to prevent possible intruders.
- **Fences/Gates**: The first line of defense should be a perimeter fence as the openness of many sites renders them highly vulnerable to intruders. Access to the site can be controlled by using a gate either manned by a security guard or with a proximity reader. You could place bollards in front of a building to stop a car from driving through the entrance. You may even have different zones, such as a research and development department, with their own perimeter security.
- **Access Control**: Armed guards at the gates should be checking the identity of those entering. There should be an access control list for visitors who are sponsored by an internal department. The guards checking identities should be behind one-way toughened glass so that visitors cannot see inside the gatehouse.
- **Access Control Vestibules**: Someone entering a building opens one door into a space (the access control vestibule) in which the security guard can confirm their identity before being allowed to access the premises via a second door.
- **Visitor Logs**: The guards at the main entrance to a base or company will ask visitors to complete the visitor logs, and then provide some form of identification.

- **Badges**: The form of identification is retained, and they are allocated a visitor's badge that is a different color to that of employees. When they leave, they then return the badge and are handed back their form of identification. These badges should be visible at all times, and anyone that isn't displaying a badge should be challenged. Badges for members of staff might be RFID-enabled cards so that they can access the building via a card reader.
- **Lighting**: Lighting is installed for two main reasons: the first reason is so that anyone trying to enter your site at night can be seen and the second reason is for safety.
- **Cameras**: Cameras can be set up in areas around the perimeter and on doorways to detect motion. They can be set up to detect objects both day and night to alert the security team by raising an alarm.
- **Robot Sentries**: These can be set up to patrol the perimeter and can shout out warnings to deter any intruders. These sentries patrol the DMZ between North and South Korea and they can be armed:



Figure 1.5 – Robot sentry

> **Tip**
> Mantraps, fences, and turnstiles are all physical controls that can stop intruders.

- **Industrial Camouflage**: When you are trying to protect a highly secure area, you would design the building so that it is obscured from aerial photographs by making some of the building look like residential housing. You would disguise the entrances as well. This would make it difficult for surveillance operatives to spot it.

Building Security

In this section, we will look at different types of building security systems:

- **Security Guards**: They work at the entrance reception desk to check the identity cards of people entering the building to stop unauthorized access. These guards should be armed and one of the guards should be a dog handler. An access control list is provided to them to ensure that unauthorized personnel is denied access.
- **Two-Person Integrity/Control**: This increases the security level at the entrance to a building, ensuring that someone is available to deal with visitors even when the other person is on the phone. This would also reduce the risk of a malicious insider attack.
- **Key Management**: This is where departmental keys are signed out and signed back in daily to prevent someone from taking the keys away and cutting copies of them.
- **Mantraps**: These are turnstile devices that only allow one person in at a time. They maintain a safe and secure environment, mainly for a data center. A data center hosts many servers for different companies.
- **Proximity Cards**: These are contactless devices where a smart card is put near the proximity card device to gain access to a door or building.
- **Tokens**: Tokens are small physical devices where you touch the proximity card to enter a restricted area of a building. Some tokens allow you to open and lock doors by pressing the middle of the token itself; others display a code for several seconds before it expires.
- **Biometric Locks**: Biometrics are unique to each person; examples would be using their fingerprint, retina, palm, voice, an iris scanner, or facial recognition.
- **Electronic Locks**: With electronic locks, you no longer need a key to access a building; you only need a PIN. They can be set to fail open, where the door opens when a power cut is detected, or fail-safe, where the door remains locked.
- **Burglar Alarms**: These are set when the premises are not occupied, so when someone tries to break into your premises, it will trigger the alarm and notify the monitoring company or local police.
- **Fire Alarms/Smoke Detectors**: In a company building, there will be fire alarms or smoke detectors in every room so that when a fire breaks out and the alarms go off, the people inside the premises are allowed to escape.

- **Internal Protection**: You could have safe areas and secure enclosures; the first example would be a toughened glass container or a sturdy mesh, both with locks to reduce access. You could also have protected distribution for cabling; this looks like metal poles that would have network cables inside. Screen filters used on a desktop could prevent someone from reading the screen.
- **Conduits**: Conduits or cable distribution have cables placed inside. This protects the cables from tampering or being chewed by rodents.

> **Tip**
> Conduits and cable distribution protect the Ethernet cable between the wall jack, through the building until it reaches the patch panel.

- **Environmental Controls**: HVAC and fire suppression systems are also security controls. In a data center or a server room, the temperature needs to be kept cool or the servers inside will overheat and fail. They use a technique called hot and cold aisles to regulate the temperature.

Device Protection

In this section, we will look at different device protection systems:

- **Cable Locks**: These are attached to laptops or tablets to secure them so that nobody can steal them.
- **Air Gap**: A computer is taken off the network and has no cable or wireless connection to ensure that the data is not stolen. An example of this would be a computer in the research and development department, as we want to prevent access to it via a network cable. The only way to insert or remove data from an air-gapped machine is by using removable media such as a USB drive.

> **Tip**
> An air gap is an isolated computer; the only way to extract data is by using a USB or CD ROM.

- **Laptop Safe**: Laptops and tablets are expensive, but the data they hold could be priceless, therefore there are safes for the storage of laptops and tablets.
- **USB Data Blocker**: This device blocks the data pins on the USB device, which prevents a hacker from juice jacking, where data is stolen when you are charging your USB device in a public area.

- **Vault**: This is where data can be encrypted and stored in the cloud, giving you an extra-secure storage area. You could use a password vault on your computer to secure all of your passwords, but it is only as secure as the master password protecting it.
- **Faraday Cage**: This is a metal structure, like a metal mesh used to house chickens. The cage prevents wireless or cellular phones from working inside the company. This could be built into the structure of a room used as a secure area. They would also prevent any kind of emissions from escaping from your company.

Understanding Digital Forensics

Digital forensics is used by the police when they are investigating crimes and need to find digital evidence so that they can secure a conviction. We will be looking at computer- and web-based attacks.

In 2006, Forensic Process 19, proposed by NIST, consisted of four different phases: collection, examination, analysis, and reporting. Here's a diagram showing these phases:

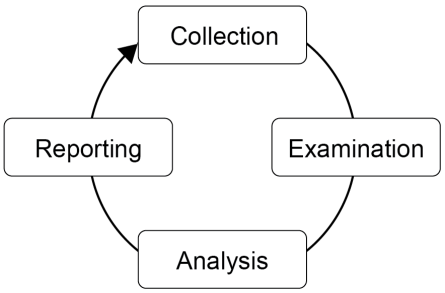


Figure 1.6 – Forensics cycle

Let's look at each of these phases:

- **Collection**: Here, the data is examined, then extracted from the media that it is on, and then converted into a format that can be examined by forensic tools.
- **Examination**: Prior to examination, the data will be hashed, and then an investigation will be carried out with the relevant forensic tool. When the examination has concluded, the data is once again hashed to ensure that the examiner or the tools have not tampered with it.
- **Analysis**: When all of the forensic data has been collected, it is analyzed and then transformed into information that can be used as evidence.
- **Reporting**: A report is compiled that can be used as evidence for a conviction.

There are many different components to a forensic investigation; we will look at each of them in turn:

- **Admissibility**: All evidence relevant to the case is deemed admissible only if it is relevant to the disputed facts of the case and does not violate any laws or legal statutes.
- **Order of Volatility**: Say you are a firefighter and you arrive at a house on fire; you can only save items one at a time and there are two items inside. The first is a snowman, and the second is a rib of beef. You now have a dilemma: which one should you choose? Easy! You save the snowman first as it is melting, and you let the rib of beef cook some more so that the other firefighters can have a nice supper! So, when we want to ascertain the order of volatility, we are looking to secure the most perishable evidence first. We do not try and stop the attack until we have secured the volatile evidence so that the source can be identified. This is known as the order of volatility. Let's look at a few examples.

  Example 1 – **Web-Based Attack**: An attacker is attacking the company website and the security team is trying to capture the network traffic to find the source of the attack. This is the most volatile evidence.

  Example 2 – **Attack inside a Computer**: When someone has attacked your computer, you need to capture the evidence in accordance with the order of volatility:

  a. **CPU Cache**: Fast block of volatile memory used by the CPU

  b. **Random Access Memory** (**RAM**): Volatile memory used to run applications

  c. **Swap/Page File/Virtual Memory**: Used for running applications when RAM is exhausted.

  d. **Hard Drive**: Data at rest for storing data

  Example 3 – **Removable Storage Drive Attached to a Computer/Server**: Someone has left a USB flash drive plugged into your fileserver. When it is in use, programs such as Word are launched in RAM, so we would capture the volatile memory first.

  Example 4 – **Command-Line Tools**: You need to know which command-line tool provides information that could disappear if you reboot the computer, and that would be `netstat`. With `netstat -an`, the listening and established ports are shown. If you reboot the computer, all of the established connections will be lost.

> **Tip**
> Order of volatility is collecting the most perishable evidence first. In a web-based attack, we should collect the network traffic with a packet sniffer.

Five-Minute Practical

Open up Command Prompt on your computer and type `netstat -an`. You should now see the listening and established ports; count them, and write the numbers down. Run the `shutdown /r /t 0` command to immediately reboot the machine. Log back in, go to Command Prompt, and run `netstat -an`; what is the difference? You will see that you have lost information that could have been used as evidence.

Collection of Evidence

In this section, we will look at different types of evidence collection:

- **E-Discovery**: During e-discovery, Cloud Service Providers (CSP) may be subpoenaed so that we can collect, review, and interpret electronic documents located on hard disks, USB drives, and other forms of storage.
- **Chain of Custody**: The chain of custody is one of the most crucial aspects of digital forensics, ensuring the evidence has been collected and there is not a break in the chain. It starts when the evidence has been collected, bagged, tied, and tagged, ensuring the evidence has not been tampered with. It lists the evidence and who has handled it along the way. For example, Sergeant Smith handed 15 kg of illegal substance to Sergeant Jones following a drug raid. However, when it is handed into the property room, 1 kg is missing. In this event, we would need to investigate the chain of custody. In this scenario, Sergeant Jones would be liable for the loss. Chain of custody examples are as follows:

  Example 1 – **Missing Entry on the Chain of Custody Document**: On Monday, 15 laptops were collected by the system administrator. The next day, the system administrator passed them on to the IT manager. On Wednesday, the IT director presents the 15 laptops as evidence to the court. The judge looks at the chain of custody document and notices that there was no formal handover between the IT manager and the IT director. With the handover missing, the judge wants to investigate the chain of custody.

Example 2 – **Evidence Leaves the Detective's Possession**: The FBI arrests a known criminal and collects 43 hard drives that they bag and tag, before placing them in two bags. They arrest the criminal and take him from Arizona to New York by airplane. One detective is handcuffed to the criminal while the other carries the two bags.

When they arrived at check-in, the airline clerk tells them that the carry-on bags are more than the 8 kg allowance, and therefore they are too heavy and need to go in the hold. The detective complies but locks the suitcases to prevent theft. Because the evidence is not physically in their possession at all times, the chain of custody is broken as there is a chance that someone working for the airline could tamper with the evidence. Therefore, they cannot prove to the court that the integrity of the evidence has been kept intact at all times.

- **Provenance**: When the chain of custody has been carried out properly and the original data presented to the court has not been tampered with, it is known as data provenance.
- **Legal Hold**: Legal hold is the process of protecting any documents that can be used in evidence from being altered or destroyed. Sometimes, this is also known as litigation hold.

  Example: Dr. Death has been prescribing new drugs to patients in a large hospital who have been dying. An auditor has been sent to investigate the possibility of foul play and then, following the audit, the FBI is notified. The doctor has been emailing a pharmaceutical company that has been supplying the drugs for a trial. The FBI does not want the doctor to be alerted, so they have the hospital's IT team put his mailbox on legal hold. When the mailbox is on legal hold, the mailbox limit is lifted; the doctor can still send and receive emails, but cannot delete anything. This way, they are not alerted to the fact that they are under investigation.
- **Data Acquisition**: This is the process of collecting all of the evidence from devices, such as USB flash drives, cameras, and computers; as well as data in paper format, such as letters and bank statements. The first step in data acquisition is to collect the volatile evidence so that it is secured. The data must be bagged and tagged and included in the evidence log.
- **Artifacts**: This can be log files, registry hives, DNA, fingerprints, or fibers of clothing normally invisible to the naked eye.
- **Time Offset**: When we collect evidence from computers, we should record the time offset. This is the regional time so that in a multinational investigation, we can put them into a time sequence—this is known as time normalization.

- **Time Normalization**: This is where evidence is collected across multiple time zones, then a common time zone, such as GMT, is used so that it can be put into a meaningful sequence.

  Example: The police in three separate countries are trying to identify where the data started from in a chain, then who handled the data along the line. They have the following information about when it was first created:

  a. **New York**: Created 3 a.m.

  b. **London**: Created 4 a.m.

  c. **Berlin**: Created 4.30 a.m.

  By recording the time offset, it looks as if it started in New York, but if we apply time normalization, when it is 4 a.m. in London, the time in New York is 11 p.m. the day before, so it cannot be New York. When it is 4.30 a.m. in Berlin, it is only 3.30 a.m. in London; therefore, it originated in Berlin. This looked the least unlikely before the time offset of the data collection had time normalization applied.

- **Time Stamps**: Each file has timestamps showing when files were created, last modified, and last accessed:

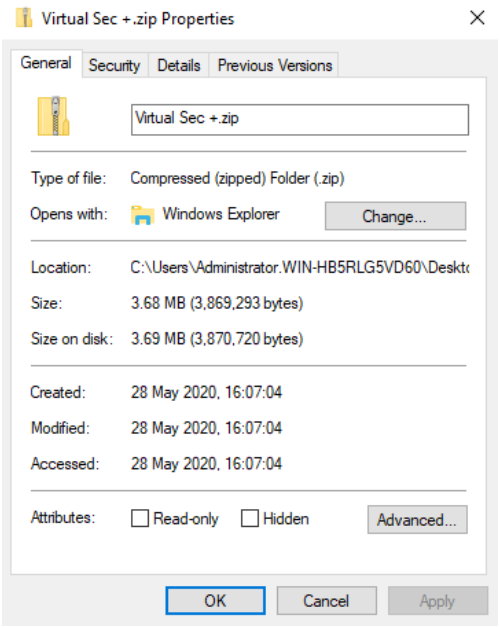


Figure 1.7 – Timestamps

- **Forensic Copies**: If we are going to analyze data stored on a removable device that we have acquired, we would first take a forensic copy and keep the original data intact. We would then use the copy to analyze the data so that we keep the original data unaltered, as it needs to be used in its original state and presented as evidence to the courts. It would be hashed at the beginning and the end to confirm that the evidence has not been tampered with.
- **Capturing System Images**: When the police are taking evidence from laptops and desktops, they take a complete system image. The original image is kept intact and the system image is analyzed to find evidence of any criminal activity. It would be installed on another computer and hashed at the beginning and the end to confirm that the evidence has not been tampered with.
- **Firmware**: Firmware, sometimes called embedded software could be reversed engineered by an attacker, therefore we must compare the source code that the developer wrote against the current source code in use. We would employ a coding expert to compare both lots of source code in a technique called regression testing. Types of attacks that affect embedded software could be rootkit and backdoor.
- **Snapshots**: If the evidence is from a virtual machine, a snapshot of the virtual machine can be exported for investigation.
- **Screenshots**: You may also take screenshots of applications or viruses on the desktops and keep them as evidence. A better way of doing this would be to use a modern smartphone that would geotag the evidence.

> **Tip**
>
> You should capture a system image from a laptop and take a forensic copy from a removable drive

- **Taking Hashes**: When either the forensic copy or the system image is being analyzed, the data and applications are hashed at the beginning of the investigation. It can be used as a checksum to ensure integrity. In the end, it is re-hashed and should match the original hash value to prove data integrity.
- **Network Traffic and Logs**: When investigating a web-based or remote attack, we should first capture the volatile network traffic before stopping the attack. This will help us identify the source of the attack. In addition to this, we should look at different log files from the firewall, NIPS, NIDS, and any server involved. If we use a **Security Information Event Management** (**SIEM**) system, this can help collate these entries and give a good picture of any attack. However, if it is a rapidly expanding virus, we would quarantine it.

Example: Your company uses an account lockout of three attempts. If an attacker tries to log in once to three separate computers, each computer would not identify it as an attack, as it is a single attempt on each computer, but a SIEM system would pick up these attempts as three failed logins attempts and alert the administrators in real-time.

> **Tip**
> You should remove a computer with a dynamically expanding virus immediately rather than collect the network traffic.

- **Capturing Video**: CCTV can be a good source of evidence for helping to identify attackers and the time the attack was launched. This can be vital in apprehending suspects.
- **Interviews**: The police may also take witness statements to try and get a picture of who was involved and maybe then use photo-fits so that they can be apprehended.
- **Preservation**: Data needs to be preserved in its original state so that it can be produced as evidence in court. This is why we take copies and analyze the copies so that the original data is not altered and is pristine. Putting a copy of the most vital evidence in a WORM drive will prevent any tampering with the evidence, as you cannot delete data from a WORM drive. You could also write-protect the storage drives.
- **Recovery**: When the incident has been eradicated, we may have to recover the data from a backup; a faster method would be a hot site that is already up and running with data less than 1 hour old. We may also have to purchase additional hardware if the original hardware was damaged during the incident.
- **Strategic Intelligence/Counterintelligence Gathering**: This is where different governments exchange data about cyber criminals so that they can work together to reduce threats. It is also possible for companies who have suffered an attack to log as much information as they can and have a third party who specializes in incident response to help them find a way to prevent re-occurrence.
- **Active Logging**: To track incidents, we need to be actively monitoring and actively logging changes to patterns in our log files or traffic patterns in our network. Installing a SIEM system that provides real-time monitoring can help collate all entries in the log files, ensuring that duplicate data is not used so that a true picture can be taken. Alerts based on certain triggers can be set up on our SIEM system so that we are notified as soon as the event happens.

Cloud Forensics

In the last few years, the growth of cloud computing and resources has been increasing year on year. Cloud forensics has different needs than traditional forensics. One of the primary aspects that a cloud provider must provide is the security of the data stored in the cloud.

In 2012, Cloud Forensic Process 26 was created to focus on the competence and admissibility of evidence. The stages are as follows:

- **Stage A** – Verify the purpose of cloud forensics.
- **Stage B** – Verify the type of cloud service.
- **Stage C** – Verify the type of technology behind the cloud.
- **Stage D** – Verify the role of the user and negotiate with the **Cloud Service Provider** (**CSP**) to collect the evidence required.

Cloud services, because of the nature of their business, create virtual machines and then destroy them regularly. This prevents the collection of forensic evidence. The forensic team needs to prove to the cloud provider their reasons for the collection of the evidence and they have to rely on the cloud provider sending them the correct evidence that they require.

Right-to-Audit Clauses

By inserting right-to-audit clauses into supply chain contracts, an auditor can visit the premises without notice and inspect the contractor's books and records to ensure that the contractor is complying with its obligation under the contract. This would help them identify the following:

- Faulty or inferior quality of goods
- Short shipments
- Goods not delivered
- Kickbacks
- Gifts and gratuities to company employees
- Commissions to brokers and others
- Services allegedly performed that weren't needed in the first place, such as equipment repairs

Regulatory and Jurisdiction

Cloud data should be stored and have data sovereignty in regions. The US introduced the CLOUD Act in 2018 due to the problems that the FBI faced in forcing Microsoft to hand over data stored in Ireland. In 2019, the UK received royal assent for the Overseas Production Act (COPOA), which allows the UK to seek data stored overseas as part of a criminal investigation. In 2019, the US and the UK signed a data-sharing agreement to give law enforcement agencies in each country faster access to evidence held by providers, such as social media or web hosting. In 2016, a similar agreement was set between the US and the EU; however, with the introduction of **the General Data Protection Regulation** (**GDPR**), all websites in the US that have consumers from the EU have to abide by GDPR.

Data Breach Notifications/Laws

If a data breach occurs, a company can be fined more than £10 million for failing to report a breach. The EU uses GDPR, and notifications of data breaches must be reported within 72 hours. Other countries have their own reporting timescale.

Review Questions

Now it's time to check your knowledge. Answer these questions and check your answers, found in the *Solutions* section at the end of the book:

1. What are the three components of the CIA triad?
2. Why might an inactive CCTV camera be placed on the outside wall of a building?
3. What does confidentiality mean?
4. How can you control access of personnel to a data center?
5. What is the purpose of an air gap?
6. Name three main control categories.
7. Name three physical controls.
8. Following an incident, what type of control will be used when researching how the incident happened?
9. How do you know whether the integrity of your data is intact?
10. What is a corrective control?
11. What type of control is it when you change the firewall rules?
12. What is used to log in to a system that works in conjunction with a PIN?

13. What is the name of the person who looks after classified data? Who gives people access to the classified data?
14. When you use a DAC model for access, who determines who gains access to the data?
15. What is least privilege?
16. What access is granted by the Linux file permission of 764?
17. The sales team is allowed to log in to the company system between 9 a.m. and 10 p.m. What type of access control is being used?
18. Two people from the finance team are only allowed to authorize the payment of checks. What type of access control are they using?
19. What is the purpose of the defense in-depth model?
20. When someone leaves the company, what is the first thing you should do with their user account?
21. What do US companies that host websites in the US have to comply with if customers are based in Poland?
22. How can a company discover that its suppliers are using inferior products?
23. What is one of the most important factors between someone being arrested and their appearance before the judge in court?
24. Can you explain what the purpose of the CLOUD Act and COPOA is?
25. What is Stage C of Cloud Forensic Process 26?